

VULNERABILITY ASSESSMENT REPORT

OWASP Juice Shop — Web Application Security Assessment

TARGET APPLICATION

OWASP Juice Shop

ASSESSMENT TYPE

Vulnerability Assessment / Security Testing

TOOLS USED

Nmap, Nikto, Dirsearch, cURL

DATE

September 2026

PREPARED BY

NITHIN VIGNESH S

Table of Contents

1.	Executive Summary
2.	Methodology
3.	Technical Findings
4.	Impact Analysis
5.	Risk Rating Summary
6.	Remediation
7.	Conclusion
8.	Evidence List

1. Executive Summary

A vulnerability assessment was performed against the OWASP Juice Shop application hosted at **172.16.16.161:3000** in an authorized laboratory environment.

The assessment identified several security-relevant observations, including an exposed web service, publicly accessible application directories, information disclosure through the **/ftp** directory, and application responses indicating potentially improper handling of unexpected requests.

The most significant finding was the publicly accessible **/ftp** directory. Directory enumeration revealed multiple files that appear to contain internal, backup, configuration, or potentially sensitive information, including:

- acquisitions.md
- announcement_encrypted.md
- coupons_2013.md.bak
- encrypt.pyc
- incident-support.kdbx
- package-lock.json.bak
- package.json.bak
- suspicious_errors.yml

The application's **robots.txt** also explicitly contains:

```
User-agent: *  
Disallow: /ftp
```

However, the **/ftp** directory remained directly accessible.

Overall, the assessment demonstrates that the application exposes unnecessary information and attack surface. These issues could assist an attacker during reconnaissance and potentially lead to further compromise depending on the contents and protections of the exposed files.

2. Methodology

The assessment followed a basic vulnerability-assessment workflow, progressing from target identification through service enumeration, web-server assessment, directory enumeration, and manual verification.

2.1 Target Identification

The application was identified as an OWASP Juice Shop instance accessible through `http://172.16.16.161:3000`. Connectivity was verified using `cURL`, which returned:

```
HTTP/1.1 200 OK
```

2.2 Port and Service Enumeration

Nmap was used to identify accessible ports and services on the target.

Evidence: 01-Nmap-Port-Service-Scan.png, nmap-juice-shop.txt

The assessment confirmed that TCP port 3000 was hosting the web application.

2.3 Web Server Assessment

Nikto was used to perform web-server and application-level reconnaissance.

Evidence: 02-Nikto-Scan-Findings.png

The Nikto scan was used to identify potentially interesting server-side findings and exposed resources.

2.4 Directory Enumeration

Dirsearch was used to discover accessible directories and files. The scan identified several interesting endpoints, including:

/assets	/ftp	/media	/profile
/promotion	/redirect	/rest	/restaurants
/restore	/restored	/restricted	/robots.txt
/video			

Evidence: 03-Dirsearch-Scan.png

2.5 Manual Verification

Discovered resources were manually checked using `cURL` to verify that the findings were accessible from the target.

3. Technical Findings

Finding 1 — Publicly Accessible FTP Directory

HIGH

Description

The /ftp directory was discovered through directory enumeration and was accessible without authentication. The directory exposed multiple files, including backup files, documentation, compiled code, configuration-related files, and a KeePass database file. Examples include: acquisitions.md, announcement_encrypted.md, coupons_2013.md.bak, encrypt.pyc, incident-support.kdbx, package-lock.json.bak, package.json.bak, and suspicious_errors.yml.

Evidence

The /ftp endpoint returned HTTP 200 and displayed a directory listing containing the files noted above. The following command was used to verify access:

```
curl http://172.16.16.161:3000/ftp
```

The output demonstrated that the files were directly accessible.

Evidence: 04-FTP-Robots-Findings.png

Impact

- Public exposure of internal files can provide attackers with valuable information about the application.
- Depending on file contents, exposed files could reveal application configuration, development information, internal documentation, backup data, source-code-related information, credentials or secrets, and database-related information.
- The presence of **incident-support.kdbx** is particularly concerning because KeePass database files may contain sensitive credentials.

Risk Rating

High

Remediation

- Remove the /ftp directory from production deployments.
- Prevent directory listing.
- Restrict access to sensitive files.
- Remove backup files such as .bak files from publicly accessible directories.
- Remove compiled/source-related files that are not required by the application.
- Ensure sensitive databases are stored outside the web root.
- Implement authentication and authorization for sensitive resources.

Finding 2 — robots.txt Information Disclosure

LOW

Description

The application's robots.txt file was accessible and explicitly referenced the /ftp path via a Disallow directive.

Evidence

Command:

```
curl http://172.16.16.161:3000/robots.txt
```

Result:

```
User-agent: *
```

```
Disallow: /ftp
```

Impact

The file itself does not provide access control. The /ftp directory remained accessible even though it was listed as disallowed. The entry therefore provides an attacker with an additional clue about a potentially interesting application path.

Risk Rating

Low

Remediation

- Do not rely on robots.txt to protect sensitive resources.
- Protect sensitive directories through authentication, authorization, web-server access controls, and application-level access controls instead.

Finding 3 — Excessive / Unexpected Application Responses

MEDIUM

Description

Directory enumeration produced multiple HTTP 500 responses for unexpected paths, including /api, /apis, /profile, /redirect, /rest, /restaurants, /restore, /restored, and /restricted. These responses indicate that the application processed unexpected requests and generated server-side errors. The assessment did not establish that these responses directly resulted in code execution or data compromise.

Evidence

Dirsearch identified multiple 500 responses during enumeration, for example:

```
500 - 2KB - /api
```

```
500 - 2KB - /rest
```

```
500 - 2KB - /restore
```

```
500 - 2KB - /restricted
```

Impact

- Reveals application behavior.
- Increases the attack surface.
- Assists attackers during reconnaissance.
- Potentially exposes debugging or implementation details.
- Indicates insufficient input/path validation.

Risk Rating

Medium

Remediation

- Properly handle invalid and unexpected requests.
- Return appropriate HTTP status codes.
- Prevent internal exception details from reaching users.
- Implement centralized error handling.
- Log errors securely on the server side.
- Validate and sanitize request paths.

Finding 4 — Exposed Application Resources

LOW-MEDIUM

Description

Directory enumeration identified several accessible resources, including /assets, /media, /promotion, and /video. Some resources returned HTTP 200, while others returned redirects.

Impact

Public application resources are not necessarily vulnerabilities. However, unnecessary exposed resources can increase the application's attack surface and provide useful information during reconnaissance. The /ftp resource is more significant because it exposed a directory listing containing potentially sensitive files.

Risk Rating

Low–Medium

Remediation

- Review all publicly accessible resources.
 - Remove unused files and directories.
 - Disable directory listing where it is unnecessary.
 - Restrict administrative or internal resources.
 - Ensure only required application content is exposed.
-

4. Impact Analysis

The primary security concern identified during the assessment is **information disclosure**.

An attacker who can access exposed files may obtain information that assists further attacks. For example, backup files and configuration-related files may reveal application structure, dependencies, implementation details, or potentially sensitive information.

The exposed /ftp directory is particularly important because it provides direct access to numerous files rather than merely revealing that a directory exists.

The assessment also demonstrated that directory enumeration can identify multiple application endpoints, increasing the attack surface available to an attacker.

5. Risk Rating Summary

Finding	Severity
Publicly accessible /ftp directory and sensitive-looking files	HIGH
Unexpected HTTP 500 responses	MEDIUM
Exposed application resources	LOW-MEDIUM
/robots.txt revealing /ftp	LOW
OVERALL RISK	HIGH

The overall rating is primarily driven by the publicly accessible /ftp directory and the potentially sensitive files exposed within it.

6. Remediation

Priority 1 — Remove Sensitive Files from the Web Root

Remove files such as *.bak, *.kdbx, *.pyc, and other internal documents from publicly accessible directories.

Priority 2 — Restrict /ftp

The /ftp directory should not be publicly accessible unless specifically required. Implement appropriate authentication and authorization controls.

Priority 3 — Disable Directory Listing

Directory listing should be disabled for directories that do not explicitly require it.

Priority 4 — Improve Error Handling

The application should handle invalid requests without generating unnecessary server errors.

Priority 5 — Review Exposed Resources

Review all discovered paths and remove resources that are unnecessary for normal application functionality.

Priority 6 — Protect Sensitive Information

Sensitive credentials, databases, configuration files, backups, and internal documentation should be stored outside the publicly accessible web directory.

7. Conclusion

The vulnerability assessment of the OWASP Juice Shop application identified several security-relevant issues.

The most significant issue was the public exposure of the /ftp directory, which allowed access to multiple files including backup, documentation, compiled-code, and database-related files.

The assessment also identified multiple application paths that generated HTTP 500 responses and several publicly accessible application resources.

Although the assessment was conducted against an intentionally vulnerable laboratory application, the findings demonstrate security weaknesses that could have serious consequences if similar configurations existed in a production environment.

The recommended remediation is to restrict access to sensitive resources, remove unnecessary files from the web root, disable unnecessary directory listing, improve error handling, and regularly perform vulnerability assessments.

8. Evidence List

Evidence	Purpose
01-Nmap-Port-Service-Scan.png	Port/service discovery
nmap-juice-shop.txt	Nmap scan output
02-Nikto-Scan-Findings.png	Web/server assessment
03-Dirsearch-Scan.png	Directory enumeration
04-FTP-Robots-Findings.png	/ftp exposure and robots.txt finding

Note: OpenVAS/Nessus scanning was not included, as it was optional for this assessment.